



Proposal Teknis Proyek Akhir

Perancangan dan Implementasi Protokol Keamanan AAA pada Sistem Informasi NEMU IPB

Kelompok 7

Salma Putri Hanifah	G6401231010
Marsya Hasna Khairunnisa	G6401231015
Lathiifa Zahira Yahya	G6401231154

1. Gambaran Umum Sistem

NEMU IPB merupakan sistem informasi berbasis web yang digunakan untuk membantu sivitas akademika IPB dalam melaporkan, mencari, memverifikasi, dan mengelola barang hilang maupun barang ditemukan. Sistem ini telah memiliki fitur dasar seperti login, pelaporan kehilangan, pelaporan penemuan, koleksi barang, verifikasi admin, klaim barang, notifikasi, serah terima barang, dan pencatatan aktivitas.

Sebagai sistem yang memproses data pengguna, laporan barang, klaim kepemilikan, dan bukti serah terima, NEMU IPB membutuhkan mekanisme keamanan yang lebih kuat. Proyek akhir ini berfokus pada perancangan dan implementasi protokol keamanan Authentication, Authorization, dan Accounting (AAA) pada sistem informasi yang sudah ada, serta penambahan fitur keamanan kriptografi untuk menjaga kerahasiaan, integritas, keaslian, dan akuntabilitas data.

2. Latar Belakang

Sistem informasi yang melibatkan pengguna internal kampus perlu memastikan bahwa setiap akses dilakukan oleh identitas yang sah, setiap pengguna hanya dapat melakukan tindakan sesuai kewenangannya, dan setiap aktivitas penting dapat ditelusuri kembali. Tanpa penerapan AAA yang baik, sistem berisiko mengalami akses tidak sah, penyalahgunaan hak admin, manipulasi data laporan, klaim barang oleh pihak yang tidak berhak, serta sulitnya melakukan audit ketika terjadi insiden.

NEMU IPB telah memiliki fondasi awal berupa autentikasi berbasis password hash dan token JWT, peran pengguna seperti admin dan pengguna umum, serta tabel `activity_logs` untuk

pencatatan aktivitas. Namun, proyek akhir ini diarahkan untuk memperkuat desain tersebut menjadi protokol keamanan yang lebih sistematis, terdokumentasi, dan dapat diuji.

3. Tujuan Proyek

Tujuan proyek akhir ini adalah:

1. Merancang skema Authentication, Authorization, dan Accounting pada sistem NEMU IPB.
2. Mengimplementasikan autentikasi pengguna berbasis password hash dan token akses.
3. Mengimplementasikan otorisasi berbasis peran agar endpoint sensitif hanya dapat diakses oleh pengguna yang berhak.
4. Mengimplementasikan accounting melalui pencatatan aktivitas penting pada sistem.
5. Menambahkan fitur kriptografi untuk menjaga integritas dan keaslian dokumen serah terima barang.
6. Mengidentifikasi aset sistem yang perlu dilindungi dalam penerapan AAA.
7. Menguji mekanisme keamanan melalui skenario akses sah, akses tidak sah, perubahan data, klaim, dan audit log.

4. Deskripsi Sistem Existing

4.1 Gambaran Umum

NEMU IPB menggunakan arsitektur client-server. Frontend dibangun menggunakan React sebagai antarmuka pengguna, sedangkan backend dibangun menggunakan FastAPI sebagai penyedia layanan API. Data sistem disimpan dalam basis data relasional dan diakses melalui SQLAlchemy ORM.

Pengguna sistem terdiri dari pengguna umum dan admin. Pengguna umum dapat membuat laporan kehilangan atau penemuan, melihat koleksi barang, melihat laporan miliknya, menerima notifikasi, dan mengajukan klaim. Admin dapat memverifikasi laporan, mengubah status barang, memproses klaim, melihat dashboard, mengekspor laporan, dan memantau log aktivitas.

4.2 Modul Sistem

Modul	Fungsi Utama
Auth	Login pengguna, verifikasi password, dan pembuatan token akses.
Barang	Pencarian, filter, daftar, dan detail barang.

Laporan	Pembuatan laporan kehilangan/penemuan dan akses detail laporan.
Admin	Verifikasi laporan, perubahan status barang, dashboard, ekspor data, dan log aktivitas.
Klaim	Pengajuan klaim barang dan verifikasi klaim oleh admin.
Notifikasi	Pengiriman dan pembacaan notifikasi pengguna.
Serah terima	Pembuatan dan verifikasi dokumen serah terima barang.

4.3 Data Utama

Entitas	Data yang Disimpan
User	Nama, email, identitas, nomor HP, password hash, role, dan status akun.
Barang	Nama barang, kategori, deskripsi, tanggal kejadian, lokasi, dokumentasi, dan status barang.
Laporan	Jenis laporan, status laporan, status verifikasi, catatan verifikasi, pelapor, admin pemverifikasi, dan barang terkait.
KlaimBarang	Pengguna mengklaim, barang, laporan kehilangan terkait, status klaim, dan catatan admin.
SerahTerima	Dokumen serah terima, hash dokumen, digital signature, public key, admin, pengguna, dan barang.
ActivityLog	Aktivitas penting, objek terkait, admin pelaksana, catatan, dan waktu aktivitas.

Notifikasi	Pesan notifikasi, pengguna tujuan, laporan terkait, tanggal kirim, dan status baca.
------------	---

5. Ruang Lingkup Proyek AAA

Proyek ini tidak membangun ulang seluruh sistem NEMU IPB dari awal. Fokus proyek adalah memperkuat lapisan keamanan pada sistem yang sudah ada melalui desain dan implementasi AAA serta fitur kriptografi pendukung.

5.1 Authentication

Authentication bertujuan memastikan bahwa pengguna yang masuk ke sistem adalah pengguna yang valid.

Rancangan autentikasi yang digunakan:

Komponen	Rancangan
Identitas login	Username yang dipetakan menjadi email domain IPB, misalnya username@apps.ipb.ac.id.
Verifikasi password	Password diverifikasi terhadap password_hash menggunakan algoritma hashing password.
Token sesi	Setelah login berhasil, backend menghasilkan access token berbasis JWT.
Isi token	Token memuat user_id, nama pengguna, role, dan waktu kedaluwarsa.
Proteksi endpoint	Endpoint yang membutuhkan login menggunakan dependency get_current_user.
Masa berlaku token	Token memiliki masa berlaku berdasarkan konfigurasi ACCESS_TOKEN_EXPIRE_MINUTES.

Skenario implementasi:

1. Pengguna mengirim username dan password melalui halaman login.
2. Backend mencari akun berdasarkan email yang dibentuk dari username.
3. Backend memverifikasi password menggunakan hash yang tersimpan.
4. Jika valid, backend menerbitkan JWT.
5. Frontend menyimpan token dan mengirimkannya pada request berikutnya melalui header Authorization: Bearer.
6. Backend memvalidasi token sebelum memproses endpoint yang dilindungi.

5.2 Authorization

Authorization bertujuan memastikan bahwa pengguna hanya dapat mengakses fitur sesuai role dan kepemilikannya.

Rancangan otorisasi yang digunakan:

Role	Hak Akses
Pengguna umum	Membuat laporan, melihat koleksi barang, melihat laporan milik sendiri, mengajukan klaim, membaca notifikasi milik sendiri, dan melihat dokumen serah terima yang terkait.
Admin	Memverifikasi laporan, menolak laporan, menyetujui laporan, mengubah status barang, memverifikasi klaim, membuat dokumen serah terima, melihat log aktivitas, dan mengekspor data.

Mekanisme otorisasi yang dirancang:

1. Role pengguna disimpan pada tabel users.
2. Token JWT membawa informasi role untuk identifikasi awal.
3. Backend tetap mengambil data pengguna dari database saat validasi token.
4. Endpoint admin menggunakan fungsi pemeriksaan admin, misalnya `ensure_admin`.
5. Endpoint data personal memeriksa kepemilikan data berdasarkan `current_user.user_id`.
6. Jika role atau kepemilikan tidak sesuai, sistem mengembalikan respons penolakan akses.

Contoh endpoint yang perlu dilindungi secara khusus:

Endpoint/Fitur	Aturan Otorisasi
Verifikasi laporan	Hanya admin.
Update status barang	Hanya admin.
Verifikasi klaim	Hanya admin.
Ekspor laporan dan log	Hanya admin.
Laporan kehilangan milik pengguna	Hanya pengguna pemilik laporan.
Notifikasi pengguna	Hanya pengguna pemilik notifikasi.
Klaim barang	Hanya pengguna yang sudah login.

5.3 Accounting

Accounting bertujuan mencatat aktivitas penting agar tindakan dalam sistem dapat diaudit.

Rancangan accounting yang digunakan:

Aktivitas	Data yang Dicatat
Login berhasil/gagal	User/email, waktu, status, dan sumber request jika tersedia.
Pembuatan laporan	User, laporan, barang, jenis laporan, dan waktu.
Verifikasi laporan	Admin, laporan, hasil verifikasi, catatan, dan waktu.
Perubahan status barang	Admin, barang, status lama, status baru, dan waktu.
Pengajuan klaim	User, barang, laporan kehilangan, dan waktu.
Verifikasi klaim	Admin, klaim, status klaim, catatan, dan

	waktu.
Pembuatan dokumen serah terima	Admin, klaim, barang, hash dokumen, dan waktu.
Ekspor data	Admin, jenis data yang diekspor, dan waktu.

Accounting diimplementasikan melalui tabel `activity_logs` dan fungsi pencatatan aktivitas. Setiap tindakan sensitif perlu menghasilkan log yang cukup untuk menjawab pertanyaan: siapa melakukan apa, terhadap objek apa, kapan dilakukan, dan apa hasilnya.

6. Fitur Kriptografi yang Diimplementasikan

Selain AAA, proyek ini menambahkan fitur kriptografi untuk meningkatkan keamanan data dan proses bisnis.

6.1 Password Hashing

Password pengguna tidak disimpan dalam bentuk plaintext. Sistem menyimpan `password_hash` dan melakukan verifikasi password menggunakan algoritma hashing password (bcrypt/Argon2). Mekanisme ini melindungi password pengguna jika database terbaca oleh pihak tidak berwenang.

6.2 JWT Signing

Token akses JWT ditandatangani menggunakan `SECRET_KEY` dan algoritma yang dikonfigurasi pada backend. Tanda tangan token memastikan bahwa token tidak dapat dimodifikasi tanpa diketahui oleh server.

6.3 Hash Dokumen Serah Terima

Dokumen serah terima barang diubah menjadi nilai hash menggunakan algoritma SHA-26. Hash digunakan sebagai sidik jari digital unik dari dokumen. Jika isi dokumen berubah, nilai hash juga akan berubah total, sehingga integritas dokumen dapat diverifikasi secara akurat.

6.4 Digital Signature

Hash dokumen serah terima ditandatangani menggunakan private key RSA (asimetris). Sistem menyimpan digital signature dan public key terkait untuk proses verifikasi. Dengan mekanisme ini, sistem dapat membuktikan bahwa dokumen serah terima dibuat oleh proses yang sah dan tidak berubah setelah ditandatangani.

6.5 Verifikasi Tanda Tangan

Sistem menyediakan proses verifikasi dokumen serah terima menggunakan public key, hash dokumen, dan digital signature yang tersimpan. Jika verifikasi kriptografis berhasil, dokumen dinyatakan autentik dan integritasnya terjaga. Jika gagal, dokumen dianggap telah mengalami modifikasi atau tanda tangannya tidak valid.

7. Identifikasi Aset yang Dilindungi

7.1 Aset Informasi

Aset	Risiko Utama	Perlindungan yang Dirancang
Data pengguna	Kebocoran data pribadi dan penyalahgunaan akun.	Autentikasi, otorisasi role, pembatasan akses endpoint.
Password hash	Serangan terhadap kredensial pengguna.	Password hashing dan pembatasan akses database.
Token JWT	Pembajakan sesi dan akses tidak sah.	Expiry token, signature JWT, validasi bearer token.
Data laporan	Manipulasi laporan dan akses laporan orang lain.	Otorisasi berbasis role dan kepemilikan data.
Data barang	Perubahan status barang tanpa wewenang.	Endpoint admin dan log aktivitas.
Data klaim	Klaim palsu atau manipulasi status klaim.	Autentikasi, otorisasi admin, accounting klaim.
Dokumen serah terima	Pemalsuan bukti pengembalian barang.	Hash SHA-256 dan digital signature RSA.
Log aktivitas	Penghapusan jejak tindakan atau audit tidak lengkap.	Accounting dan pembatasan akses log hanya untuk admin.
File .env	Kebocoran SECRET_KEY dan DATABASE_URL.	Penyimpanan konfigurasi di environment dan tidak dipublikasikan.

7.2 Aset Fungsional AAA

Aset	Fungsi Keamanan
Endpoint login	Gerbang autentikasi utama pengguna.
Middleware/dependency validasi token	Memastikan endpoint terlindungi hanya menerima request bertoken valid.
Fungsi pengecekan admin	Menjaga fitur administratif agar tidak diakses pengguna umum.
Tabel activity_logs	Menyediakan jejak audit sistem.
Modul signature_service	Menyediakan hash, tanda tangan digital, dan verifikasi dokumen.
Konfigurasi JWT	Menentukan algoritma, secret, dan masa berlaku token.

7.3 Klasifikasi CIA

Aset	Confidentiality	Integrity	Availability
Data pengguna	Tinggi	Tinggi	Sedang
Password hash	Sangat tinggi	Tinggi	Sedang
Token JWT	Sangat tinggi	Tinggi	Sedang
Data laporan	Tinggi	Tinggi	Tinggi
Data barang	Sedang	Tinggi	Tinggi
Data klaim	Tinggi	Tinggi	Tinggi
Dokumen serah terima	Tinggi	Sangat tinggi	Tinggi
Digital signature	Sedang	Sangat tinggi	Tinggi

Log aktivitas	Tinggi	Sangat tinggi	Sedang
Backend API	Sedang	Tinggi	Sangat tinggi
Database	Sangat tinggi	Sangat tinggi	Sangat tinggi
File konfigurasi .env	Sangat tinggi	Tinggi	Sedang

8. Rencana Implementasi

Tahap	Aktivitas	Output
Analisis sistem existing	Mengidentifikasi modul, endpoint, role, dan data sensitif.	Daftar aset dan titik kontrol keamanan.
Perancangan AAA	Merancang autentikasi, otorisasi, dan accounting.	Desain protokol AAA dan aturan akses.
Implementasi Authentication	Memastikan login, password hash, JWT, dan validasi token berjalan.	Endpoint terlindungi dengan token.
Implementasi Authorization	Menambahkan pengecekan role dan kepemilikan data.	Endpoint admin dan endpoint personal terlindungi.
Implementasi Accounting	Mencatat aktivitas penting ke activity_logs.	Log audit untuk tindakan sensitif.
Implementasi Kriptografi	Hash dokumen, digital signature, dan verifikasi signature.	Dokumen serah terima yang dapat diverifikasi.
Pengujian	Menguji skenario akses sah, akses tidak sah, perubahan data, dan verifikasi dokumen.	Hasil uji keamanan dan fungsional.

Dokumentasi	Menyusun dokumentasi desain, implementasi, dan hasil pengujian.	Laporan proyek akhir.
-------------	---	-----------------------

9. Kesimpulan

Proyek akhir ini mengarahkan pengembangan NEMU IPB pada penguatan keamanan aplikasi melalui penerapan Authentication, Authorization, dan Accounting. Authentication memastikan pengguna yang masuk adalah pengguna sah, Authorization memastikan pengguna hanya dapat melakukan tindakan sesuai kewenangannya, dan Accounting memastikan setiap aktivitas penting dapat ditelusuri.

Penambahan fitur kriptografi seperti password hashing, JWT signing, hash dokumen, dan digital signature memperkuat perlindungan terhadap data dan proses penting, khususnya dokumen serah terima barang. Dengan rancangan ini, NEMU IPB tidak hanya menjadi sistem pelaporan barang hilang dan ditemukan, tetapi juga sistem yang memiliki mekanisme keamanan, integritas data, dan auditabilitas yang jauh lebih baik serta siap menghadapi potensi ancaman berdasarkan pemodelan STRIDE.